VAPT REPORT

Web Application Security Assessment

OWASP Juice Shop — Local Training Lab

Company	Rhombix Technologies
Assignment	Task 2: VAPT of a Web Application
Student name	Maryam Ilyas
Assessment date	22 October 2026
Environment	Local OWASP Juice Shop at http://localhost:3000

Assessment purpose

This report documents a basic, non-destructive security assessment of a deliberately vulnerable training application running locally. It records the checks performed, observed application responses, and areas requiring further testing. It is intended for educational use.

> **Scope note:** This is a limited manual test, not a comprehensive penetration test. Only observations described during the lab are recorded. No vulnerability is marked confirmed unless the available evidence supports that conclusion.

1. Executive Summary

A basic VAPT exercise was conducted against the OWASP Juice Shop application hosted locally. Tests focused on login form validation, account registration, password matching, logout behavior, access to an administration route while logged out, and product-search input handling.

Observed controls included rejection of empty login fields, rejection of a short password, a mismatch message when password and confirmation did not match, successful login with a test account, and denial of access to the administration route while logged out. A script-like search string returned “No results found”; no JavaScript alert was observed in that test.

These results show expected behavior for the specific test cases performed. They do not prove the application is free of vulnerabilities. Additional testing and evidence would be needed to assess authorization, session management, input handling, and other controls more thoroughly.

Assessment at a glance

Item	Details
Target	OWASP Juice Shop local training instance
Target URL	http://localhost:3000
Approach	Manual, browser-based checks; no destructive testing
Test areas	Login, registration, password validation, logout, access control, search input
Overall result	Expected behavior observed in recorded checks; limited coverage

2. Objective and Scope

Objective: Perform initial, safe checks of a local web application and document visible security-related behavior for an academic assignment.

In scope: The local OWASP Juice Shop interface, login and registration forms, logout behavior, the administration route while logged out, and product search.

Out of scope: Testing public or third-party systems, denial-of-service testing, destructive actions, automated exploitation, and claims of complete security coverage.

Safety: Tests are intended for the local training lab only. Use fictional test-account data; do not enter real passwords or personal information.

3. Tools and Methodology

Tool / component	Use in this exercise
OWASP Juice Shop	Deliberately vulnerable web application used as the local test target.
Web browser	Accessed the application and observed responses to form and navigation tests.
Windows screenshot utility	Captured evidence of visible application states and messages.
Manual testing	Entered controlled test values and checked messages, redirects, and access decisions.

Testing procedure

1. Opened the local Juice Shop homepage and reviewed the login interface.
2. Checked login behavior with invalid, empty, and malformed test input.
3. Opened the registration form and observed its fields and security-question options.
4. Checked password length and password-confirmation validation messages.
5. Registered a fictional test account and confirmed that login worked.
6. Logged out and checked whether the account menu returned to a Login option.
7. Attempted to open the administration route while logged out.
8. Tested a normal product search and a script-like search string, recording the visible result.

Evidence handling

Insert screenshots into the numbered evidence spaces in Section 7. Keep the browser URL and relevant message visible wherever possible. Avoid including personal information, real credentials, or unrelated desktop content.

4. Test Results

ID	Test	Observation	Assessment
T01	Homepage access	Homepage loaded at the local URL.	Informational
T02	Login page	Login form was accessible.	Informational
T03	Invalid login	Invalid credentials were rejected with an error message.	Expected control
T04	Empty login fields	The page requested an email address and password.	Expected control
T05	Email-format test	Input `abc` was rejected with “Invalid email or password”.	Inconclusive for format validation
T06	Registration form	Registration fields and security-question options were visible.	Informational
T07	Password length	Short password rejected: “Password must be 5-40 characters long.”	Expected control
T08	Password mismatch	Different password and confirmation rejected: “Passwords do not match”.	Expected control
T09	Security questions	A list of personal/security questions was available.	Review recommended
T10	Registration fields	Fictional test fields were filled before submission.	Informational
T11	Registration redirect	After submission, the application returned to the login page.	Observed behavior
T12	Successful login	Login with the test account succeeded.	Expected behavior
T13	Logout	After logout, the account menu showed “Login”.	Expected control
T14	Administration route	Access denied while logged out: “You are not allowed to access this page!”.	Expected control
T15	Product search	Searching for `apple` returned products.	Expected behavior
T16	Script-like search input	The page displayed “No results found”; no alert was observed.	No issue observed in this test

Assessment note: the results describe only the specific tests performed. They are not a certification that the application is secure.

5. Findings and Recommendations

5.1 Controls observed working

Login input handling: Empty fields and invalid test credentials were rejected with visible messages.

Password validation: A password shorter than the stated minimum was rejected, and mismatched password entries were not accepted.

Logout behavior: The account menu displayed “Login” after logout, consistent with a logged-out state.

Access control: The administration route denied access while the user was logged out.

Search behavior: The script-like query returned no results and did not produce an observed alert.

5.2 Areas for further review

Area	Why review it	Recommended next step
Security questions	Some questions may rely on personal facts that could be guessed or found publicly.	Review account-recovery design; prefer strong recovery controls and avoid relying on guessable answers alone.
Session management	A menu change does not verify token invalidation.	In an authorized lab, verify protected actions remain unavailable after logout and session tokens are invalidated.
Input handling / XSS	One search query is not sufficient to test all input contexts.	Perform structured authorized testing across relevant input fields and review safe output encoding.
Authorization	Only one logged-out access attempt was recorded.	Test protected routes and role-based access with permitted test accounts; do not access other users’ data.
Registration	Registration redirect and successful login were observed, but full registration security was not assessed.	Review duplicate-account handling, server-side validation, rate limits, and safe error messages in the lab.

6. Limitations

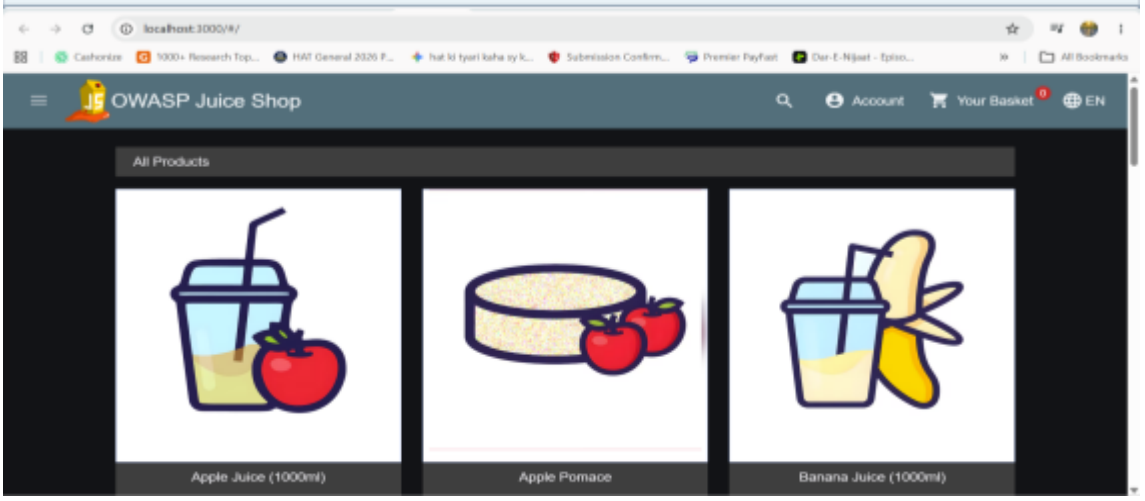
This assessment was limited to manual browser interactions and observations reported during the lab. No source-code review, automated scanner results, server logs, API testing, authenticated role comparison, or exhaustive payload testing was included. No CVSS scores are assigned because no confirmed exploitable vulnerability was established from the recorded evidence.

The security-question list is recorded as an area for review rather than a confirmed vulnerability. Likewise, the absence of a JavaScript alert for one search string is not proof that cross-site scripting is absent.

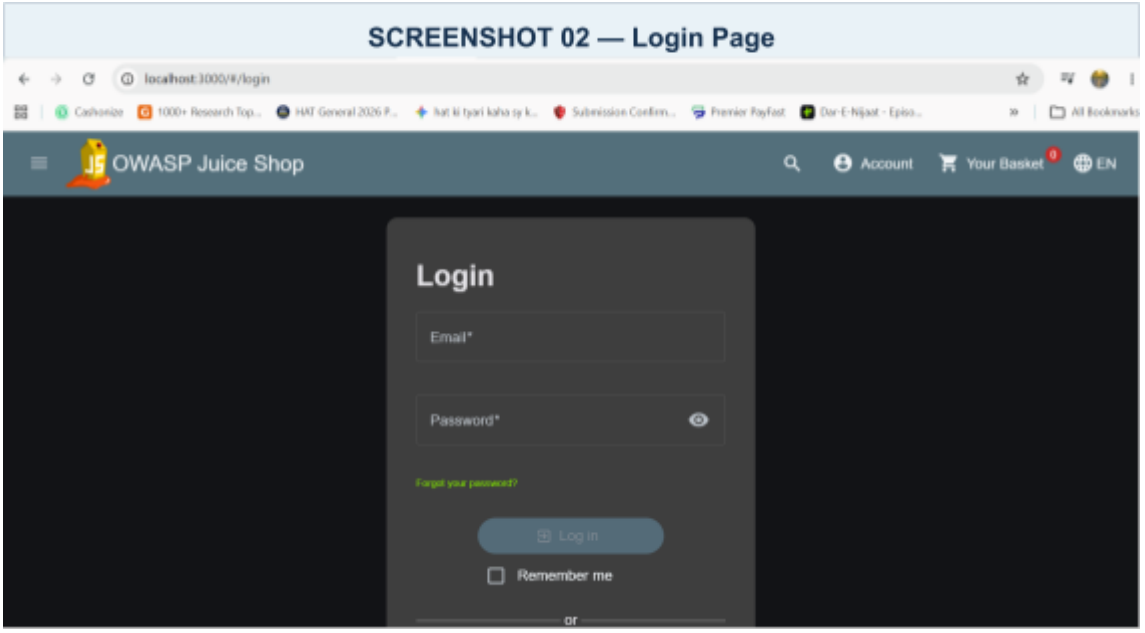
7. Screenshot Evidence Appendix

Insert the matching screenshot into each numbered box. Keep the relevant page, URL, field, or response message readable. Filenames follow the sequence used during the lab.

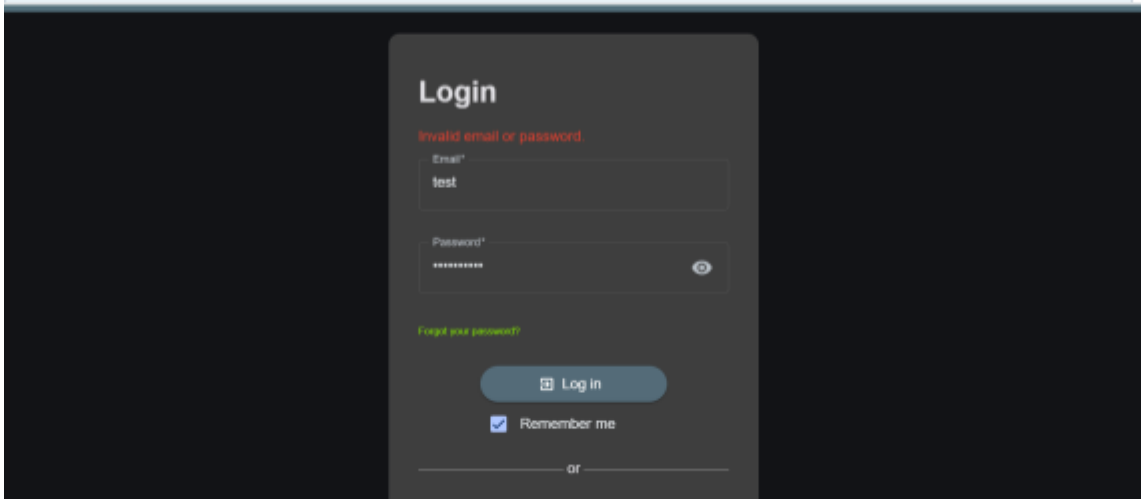
SCREENSHOT 01 — Juice Shop Homepage



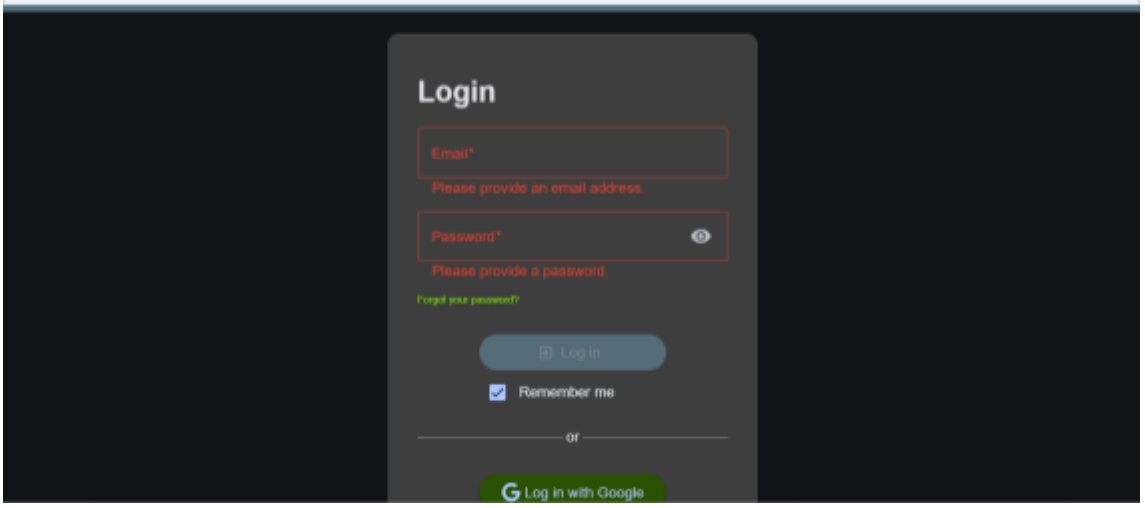
SCREENSHOT 02 — Login Page



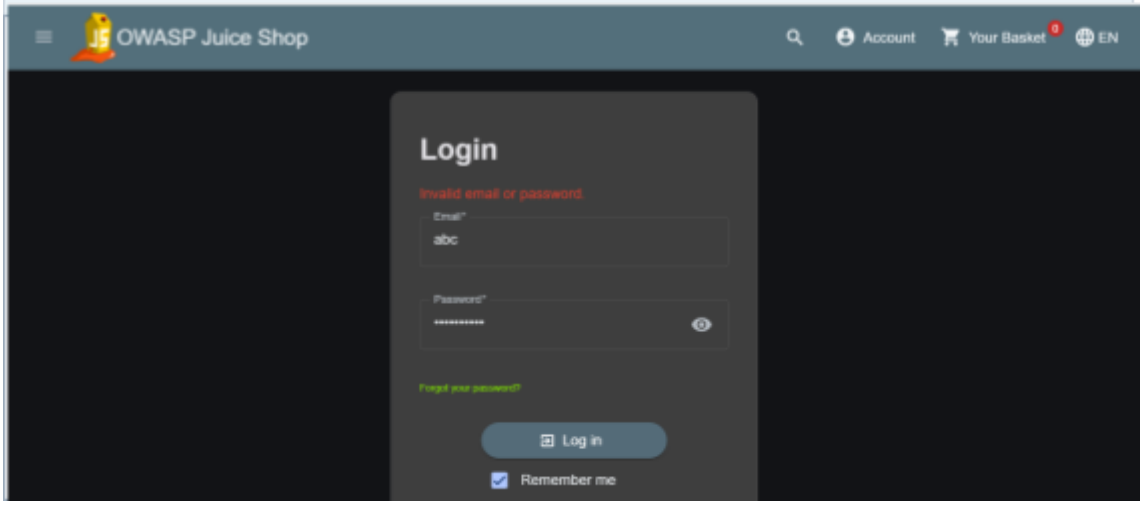
SCREENSHOT 03 — Invalid Credentials



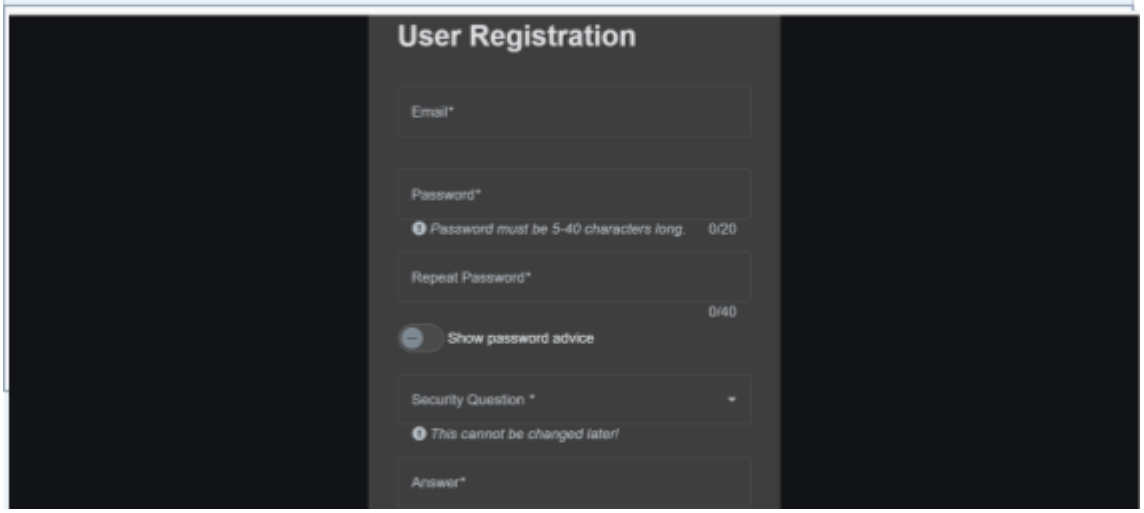
SCREENSHOT 04 — Empty Login Fields



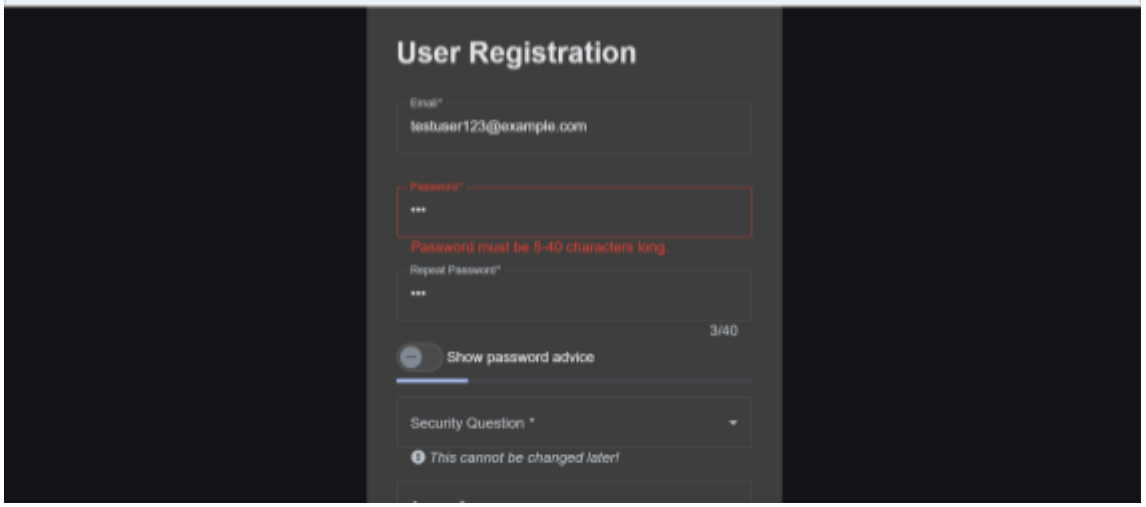
SCREENSHOT 05 — Email Format Test



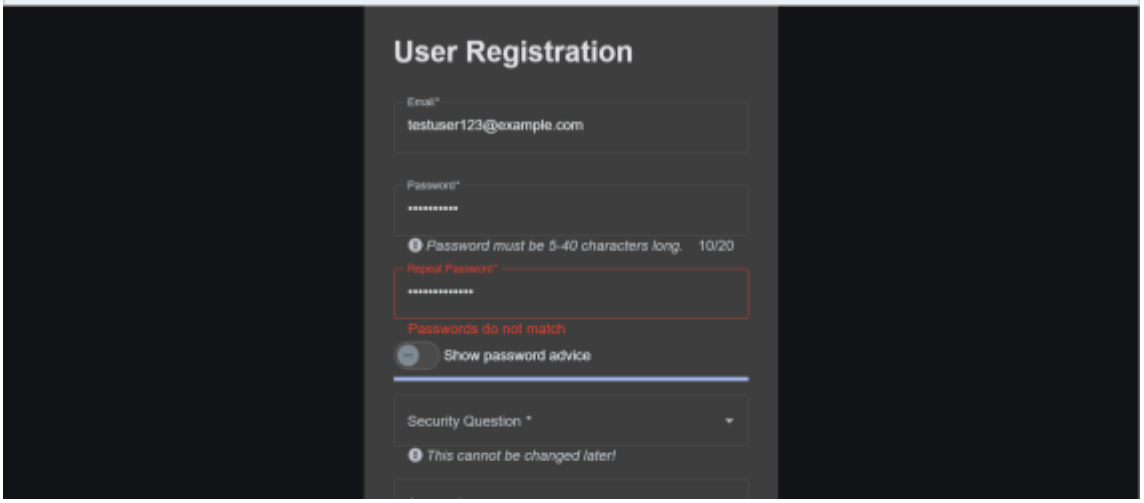
SCREENSHOT 06 — Registration Form



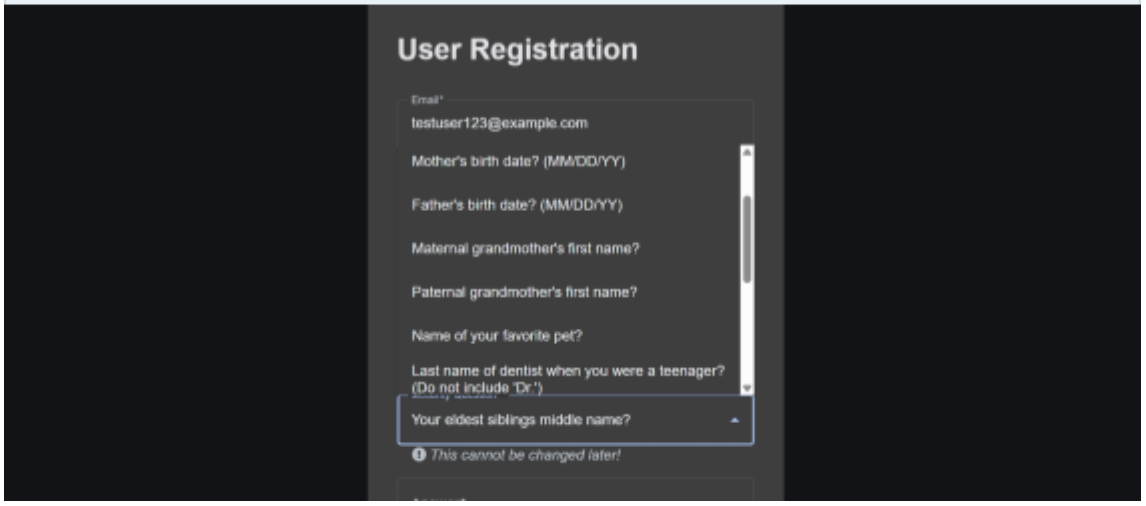
SCREENSHOT 07 — Password Length Validation



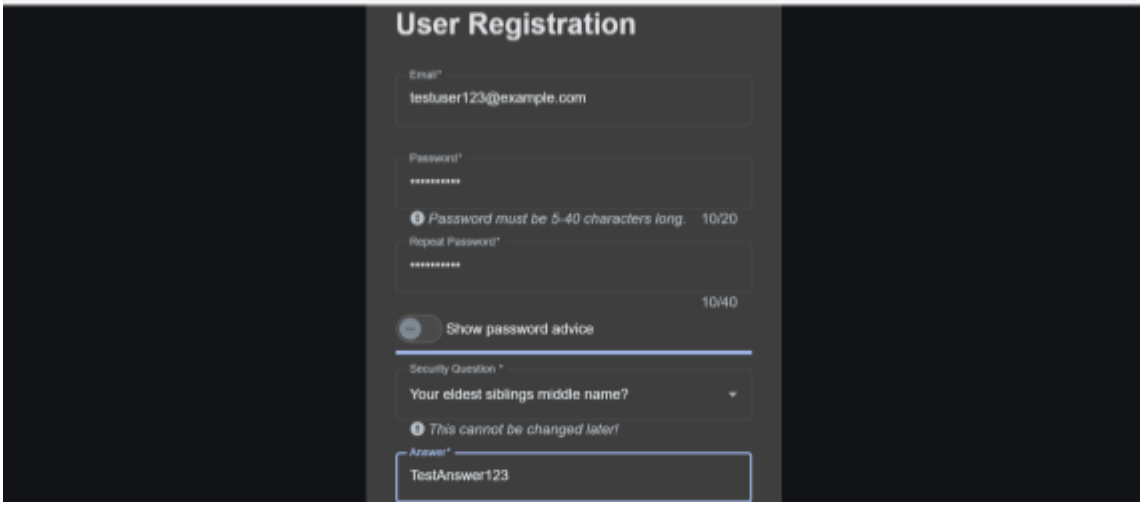
SCREENSHOT 08 — Password Mismatch Validation



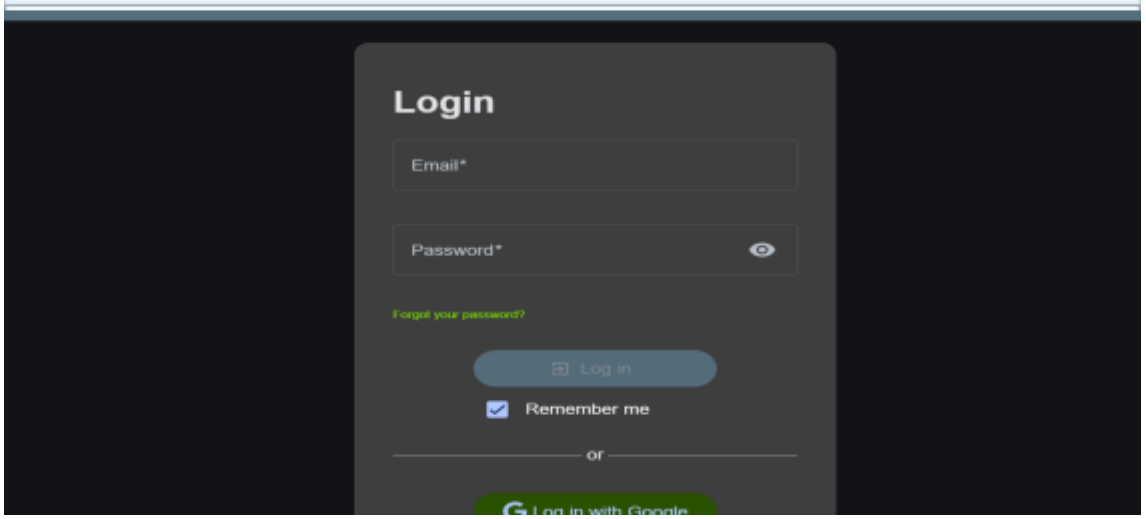
SCREENSHOT 09 — Security Questions



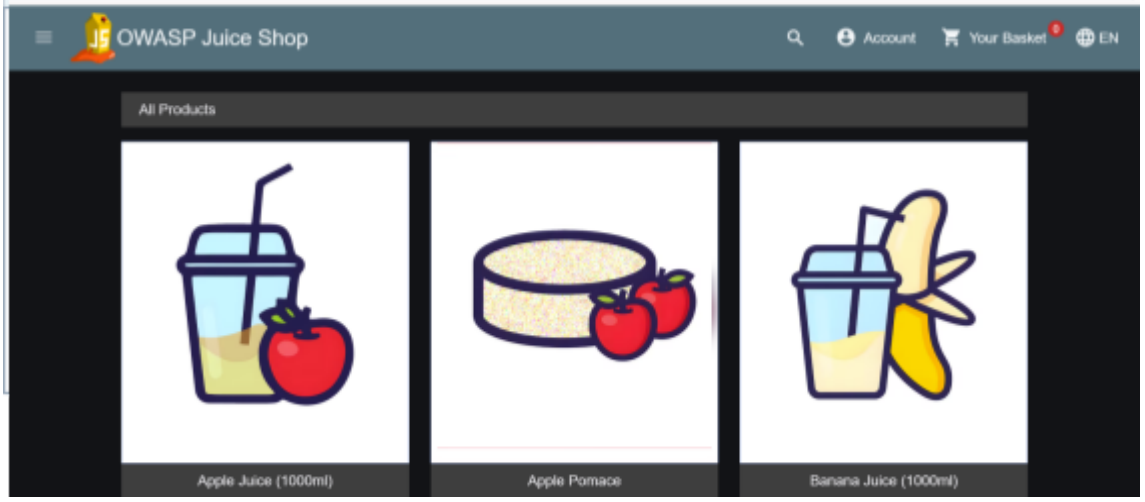
SCREENSHOT 10 — Registration Fields Completed



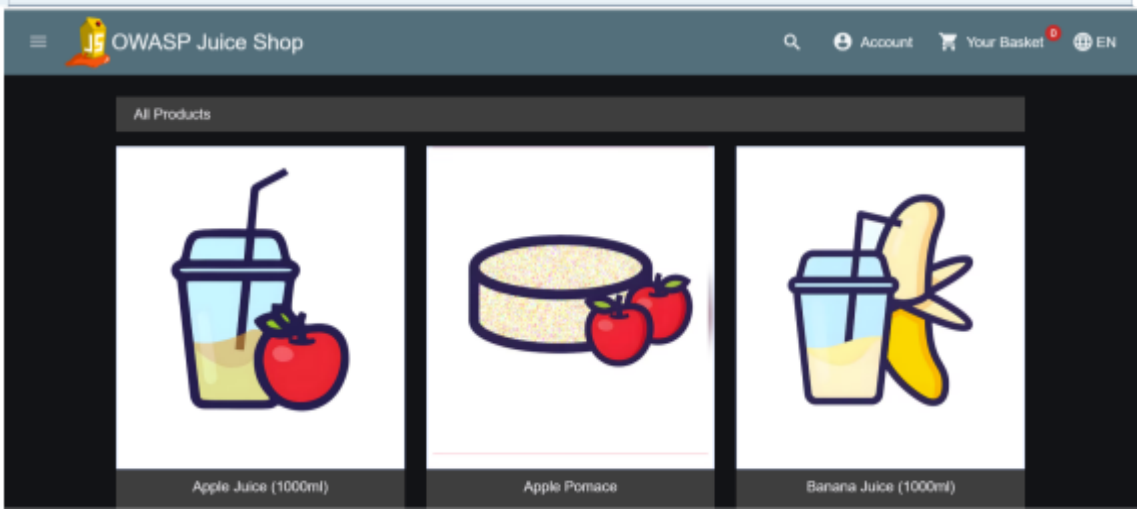
SCREENSHOT 11 — Registration Redirect



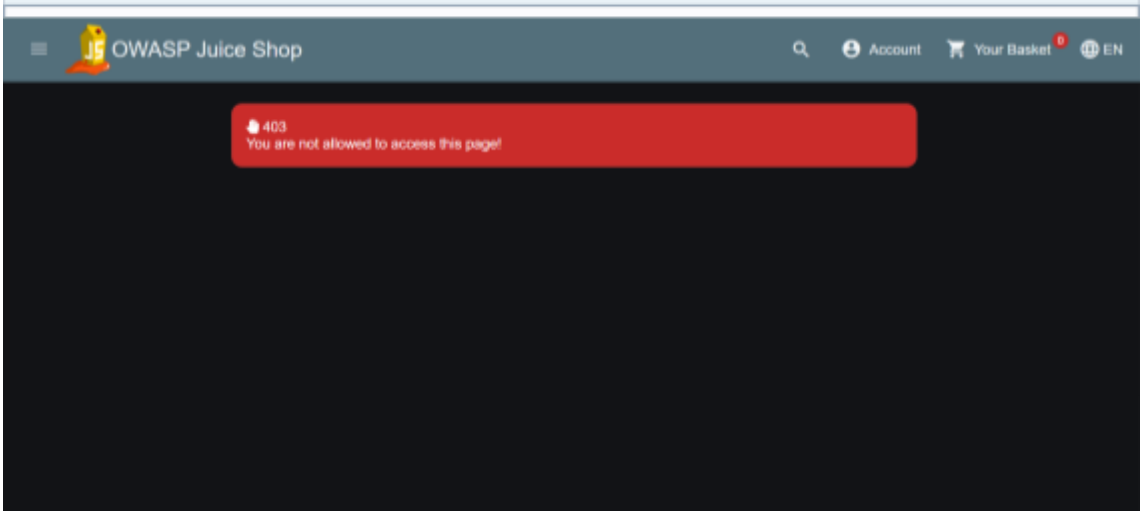
SCREENSHOT 12 — Successful Login



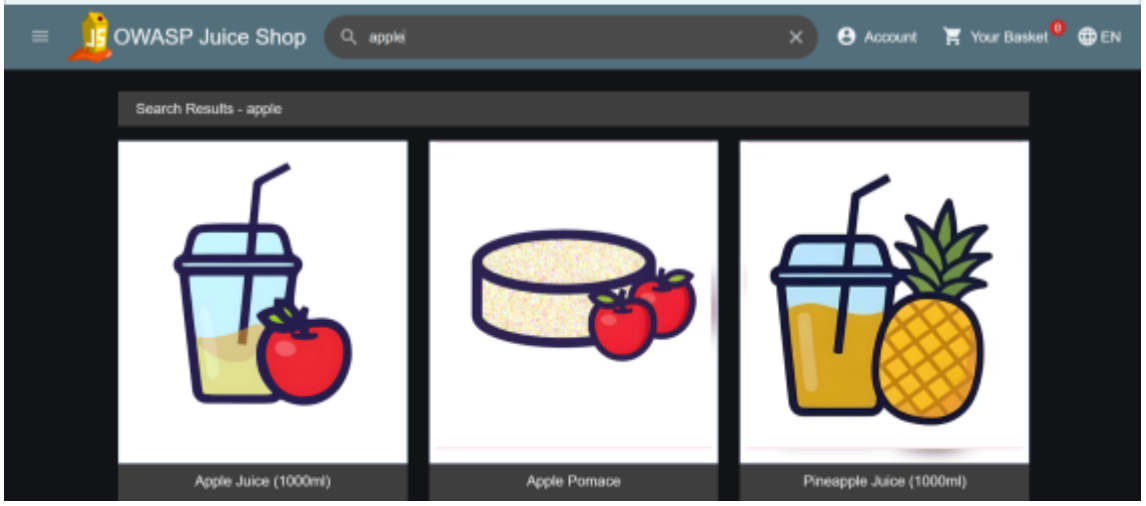
SCREENSHOT 13 — Logout Verified



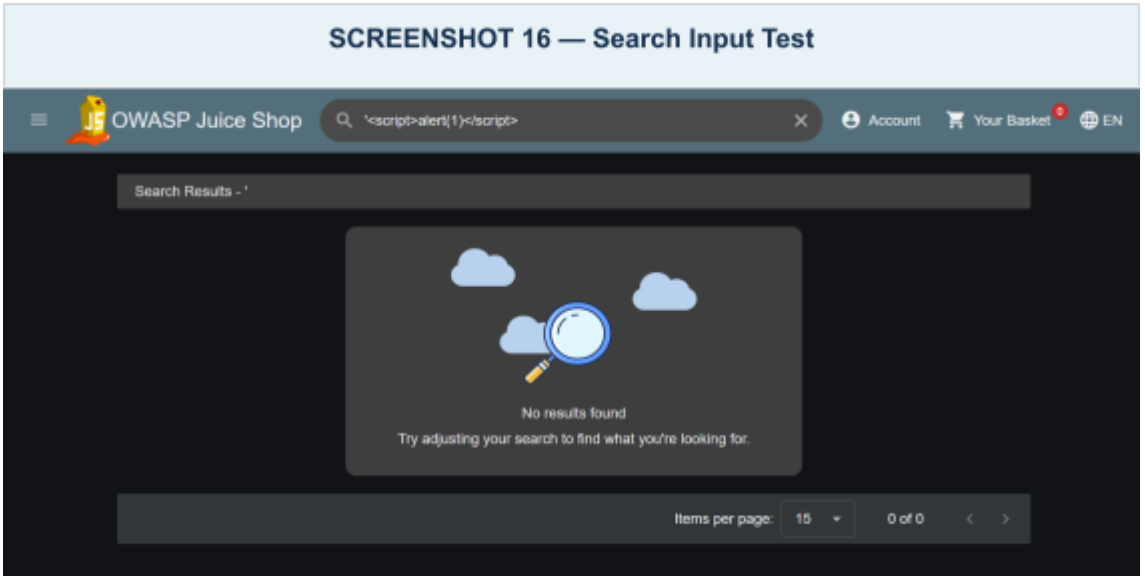
SCREENSHOT 14 — Access Control Test



SCREENSHOT 15 — Product Search



SCREENSHOT 16 — Search Input Test



8. Conclusion

The manual assessment documented several expected application behaviors in the local OWASP Juice Shop lab. The application rejected empty login fields, enforced a password-length rule, detected mismatched password entries, allowed login with the test account, displayed a Login option after logout, and denied access to the administration route while logged out. The tested script-like search query returned no results and did not trigger an observed JavaScript alert.

No confirmed exploitable vulnerability is concluded from the tests recorded in this report. Useful next steps are broader authorized checks of session invalidation, role-based authorization, account-recovery design, and input handling, with clear evidence for each result.

References

• OWASP Juice Shop project documentation: https://owasp.org/www-project-juice-shop/

• OWASP Web Security Testing Guide: https://owasp.org/www-project-web-security-testing-guide/

• OWASP Top 10: https://owasp.org/www-project-top-ten/